סיכום שמירה וגישה: מה נמחק אוטומטית, מה ידני, ומי רואה מה (אנגלית, המקור)

מסמך	סיכום שמירה וגישה: מה נמחק אוטומטית, מה ידני, ומי רואה מה (אנגלית, המקור)
נתיב המקור	docs/privacy/en/02-retention-and-access-summary.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

נוסח אנגלי: המקור, והעברי (02) עוקב אחריו סעיף אחר סעיף. הנוסח העברי נמצא באותה תיקייה.

---

02 - Retention and access summary (tickets, directory, technician data and related records)

Status: DRAFT, factual. Not legal advice. Verified against `origin/integ/290` @ `018795f96` (2026-10-19). `B/` = `smplwise_vms/backend/smplwise/`. "Default" means the value in the code when nobody changed a setting. Items marked **REQUIRES COUNSEL REVIEW** carry an id (C1...) listed in `../README.md`.

1. Retention: what the code deletes by itself, and when

Data	Deleted automatically	Mechanism (file)	Can the organisation change it?
Audit log rows	older than 365 days	`B/main.py` janitor -> `B/audit.py` `prune`	yes, setting `audit.retention_days` (30-3650) - `B/routers/settings.py`
Directory person (technician, contact, vendor)	**never automatically**	only an administrator's erase (`contacts.erase`)	n/a
Door-access grant rows (ids, doors, dates; no name)	365 days after the grant ended/was refused/failed/revoked	`B/services/access_grants.py` `alert_and_prune`, `RETENTION_DAYS = 365`	no (constant)
Code-send cap ledger (keyed number hash, time, outcome)	2 days	same function	no

Data	Deleted automatically	Mechanism (file)	Can the organisation change it?
Pending technician added by a vendor, never decided	**not deleted automatically**; appears in the "needs review" report after `directory.review_pending_days` (default 30, range 7-365); a yearly reminder is emitted in January	`B/services/needs_review.py`	yes (setting)
Idle technician (known for door access, no live grant, no activity)	**not deleted automatically**; appears in the report after `directory.review_idle_months` (default 12, range 1-60)	`B/services/needs_review.py`	yes (setting)
Person record in the door system	**never automatically**; manual per-person delete ("delete" typed) after all grants are revoked, only for persons Arx created	`B/services/access_grants.py` `delete_person_now`	n/a
Door-system entry records and entry pictures	decided by the door system, **not verified**	n/a	**REQUIRES COUNSEL REVIEW (C7)**
Closed tickets	the date `purge_after` (default closed + 730 days, bounded 90-3650 in `B/services/tickets/monitor.py`) is recorded on the ticket, **but no code was found that deletes tickets when that date passes** (`B/services/tickets/retention.py` docstring: the purge "belongs to a later slice"). A manager can delete a ticket fully by hand	`B/services/tickets/deletion.py`	the retention key is read by `monitor.py` but was not found in the settings schema (`B/services/tickets/settings_doc.py`)
Ticket request idempotency rows	24 hours	`B/services/tickets/retention.py`	no
Ticket outbound message log / inbound log	90 days / 30 days	`B/services/tickets/messaging.py` `OUTBOX_KEEP`, `INBOUND_KEEP`	no
Handler-link access log, codes, sessions	access log 90 days; codes and sessions 1 day after expiry	`B/services/tickets/public_runtime.py`	no
Phone-verification rows	2 days	`B/services/tickets/phone_verify.py` `KEEP`	no
Vendor-portal technician requests	decided: 180 days after the decision; pending: 90 days after sending	`B/services/tickets/portal_more.py`, mig 0112	no

Data	Deleted automatically	Mechanism (file)	Can the organisation change it?
Cost claims, invoice files	claim `purge_after` = approval/payment + `costs.retention_days` (default 2555 days = 7 years, minimum 730)	`B/services/tickets/costs_retention.py`, `settings_doc.py`	yes (setting); legal minimum **REQUIRES COUNSEL REVIEW (C10)**
Requests for quotation and quotes not selected	`rfq.retention_months` (default 24, range 6-120)	`B/services/tickets/rfq.py` `retention`	yes
People-messaging records (`intercom_messages`)	400 days	`B/services/intercom_messaging.py` `KEEP_DAYS`	no
Consent-by-link requests and held messages	requests (not still open) and released/dropped held messages after 400 days (`KEEP_DAYS` shared with people messaging); a granted-consent row stays until the person later declines (then it is deleted and an opt-out row is written)	`B/services/intercom_consent.py` `prune`	no
Phone-app presence event log	`presence.retention_days`, default 30, range 1-365	`B/services/presence.py` `janitor`	yes (setting)
Home Assistant entity state history (`ha_state_history`: state, change time, receipt time; used by the historical map)	30 days after receipt	`B/main.py` janitor -> `B/services/ha_history.py` `prune`, `RETENTION_DAYS = 30`	no (constant)
Presence-sensor states in that history (binary sensors of class motion / occupancy / presence)	`history.presence_retention_days`, default 7 (1-30), applied only while the time scrub (`history.timescrub`) is on; otherwise the 30 days above. Reading them on the map needs `history.presence` and writes one audit row per user, floor and day	same, `prune_presence` (CR-TIMESCRUB101)	yes (setting); whether it should apply with the time scrub off is an open owner question
History gaps (`ha_state_history_gaps`: from, to, reason - no personal data)	with the state history (30 days)	same	no
Device activity log (who changed an electrical device)	`device_activity.retention_days`, default 90 (7-365), plus size caps	`B/services/device_activity.py` `prune`	yes (setting)
Elevator state history (derived state only, no person)	8 days	`B/services/elevators.py` `HISTORY_KEEP_S`	no

Data	Deleted automatically	Mechanism (file)	Can the organisation change it?
Revoked phone-app device rows	30 days after revocation	`B/services/presence.py` `REVOKED_KEEP_DAYS`	no
Phone-app push messages	1 day after expiry (24 h life)	same	no
Camera event thumbnails and `events` rows	`events.retention_days`, default 30 (1-3650)	`B/main.py` janitor, `B/services/thumbnails.py`	yes
Notification inbox / delivery log	30 days after resolution (inbox, floor 365 days for any row) / 14 days (deliveries)	`B/services/notify.py`	partly (`retention_days` choices)
Browser push subscriptions	not synced for 120 days	`B/services/push.py` `STALE_DAYS`	no
Local-login records	used/expired links 1 week; revoked/expired sessions 1 month; reset codes about 1 hour after expiry; reset sends 24 h	`B/services/local_identity.py`, `B/services/local_reset.py`	no
Remote revoked-session chains	365 days	`B/services/ha_user_auth.py`	no
Project backups	5 "pre-upgrade" and 7 "daily" archives kept; manual/uploaded never removed by code	`B/services/backup.py` `KEEP`	no

Whether "until the organisation deletes it" without a fixed period is acceptable for directory persons and door-system persons: **REQUIRES COUNSEL REVIEW (C3)**. Whether the audit period (365 days) and the 7-year financial period are right, and how they interact with a deletion request: **REQUIRES COUNSEL REVIEW (C10)**.

2. What an erase of a directory person does and does not do

`B/services/tickets/contacts.py` `erase_checked` and `B/services/tickets/store_links.py` `erase_contact`:

- Does: revokes the person's live handler links, replaces the name with the fixed tombstone text, clears company, phone, keyed phone index, e-mail, notes, user link and phone-confirmation fields, marks the row inactive and erased, removes department rows and phone-verification rows; with the "also from history" option, replaces the person's frozen name on assignments, ticket timeline rows and RFQ timeline rows and neutralises the names of files the person uploaded; cost claims keep the company, amounts and files (`costs.on_contact_erased`). One audit row `ticket.contact.erase` (ids and counts).
- Does not (from the code): remove names or numbers a person typed into free-text ticket descriptions or notes; remove the row itself (it stays as a tombstone); delete the door-system person (a separate,

manual, per-action step); delete the access-grant rows, which expire 12 months after they end; touch backups already written.

- Refused while a live door grant exists (`B/services/needs_review.py`, 409 `needs_review_live_grant`); a vendor with persons cannot be erased (409 `contact_has_persons`).
- "Reject and delete" of a pending technician (`B/services/access_grants.py` `reject_pending_contact`) ends open requests and runs the same erase; it is refused if a door-system link or a decided grant exists.

3. Who can see what

Permissions are role-and-scope based (`B/rbac.py`; model in `docs/security/HA_IDENTITY_RBAC_HE.md`). The host administrator can reach data outside Arx's access control (same document, section 2).

Data	Who	Rule (file)
Directory list, create/edit/erase/ export	holders of `tickets.configure` at installation scope	`B/services/tickets/contacts.py` docstring
Directory contacts allowed in a department	managers of that department with `tickets.manage`	same
Full phone number	`tickets.configure`; or `tickets.external` plus managing an allowed department; others see the last four digits. Setting `directory.managers_full_phones` (default off)	`contacts.py`, `settings_doc.py`
Approve / refuse / revoke technician door access	permission `access.external.grant`, only for stations the approver is bound to; by default administrators	`B/services/access_grants.py` `PERMISSION`; `access.external.local_approvers` default off
Reject a pending technician	`access.external.grant` anywhere, or `tickets.configure`	`reject_pending_contact`
"Needs review" report and delete-now	`tickets.configure` at installation scope	`B/services/needs_review.py`
Delete a person in the door system	`access.external.grant` and unrestricted `people.manage`; interactive session	`delete_person_now`
Full ticket deletion	`tickets.delete`, manager of the department; interactive session	`B/services/tickets/deletion.py`
Vendor on the arrival page	own technicians only: first name plus the last two phone digits; the request state	`B/services/access_arrival.py` (line ~86)
Audit log	permission `audit.read` (listed in the `system_admin` role)	`B/rbac.py`, `B/roles.json`
Presence events and device status	the user for own devices; holders of `presence.sensors.view` for any device; `system.configure` to change settings	`B/routers/presence.py`
Managers' notifications about access	content-free (no name, phone or door)	`_notify` in `access_grants.py`, `needs_review.py`
Technician's personal code	the technician only (WhatsApp); nobody in Arx	`access_grants.py`

Whether holders of a general "view people/contacts" permission can see a pending technician was not verified in this pass: **REQUIRES COUNSEL REVIEW (C11)** (technical check first).